

Data Classification Policy

Document Control

Field	Value
Policy ID	POL-SEC-005
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Policy Owner	Chief Information Security Officer (CISO) / Privacy Officer
Approved By	Executive Management
Classification	Internal

1. Purpose

This policy establishes a consistent framework for classifying and protecting data at HealthPlus Medical Group based on its sensitivity and the harm that could result from unauthorized disclosure, alteration, or loss. Its purpose is to ensure that patient medical records, employee information, financial data, research data, and business information receive protection appropriate to their risk level, and to support compliance with **HIPAA**, the **GDPR**, and applicable state privacy laws.

2. Scope

2.1 Applicability

This policy applies to:

- ☒ All employees
- ☒ Contractors and consultants
- ☒ Third-party vendors and business associates
- ☒ Researchers and affiliated clinical staff

2.2 Systems/Assets Covered

This policy applies to all data created, received, maintained, or transmitted by HealthPlus Medical Group, in any format (electronic, paper, verbal) and on any system, including electronic health record (EHR) systems, email, file storage, research databases, employee HR systems, financial systems, and physical records.

2.3 Exclusions

This policy does not apply to data that has been fully and irreversibly de-identified in accordance with the HIPAA de-identification standard and no longer constitutes Protected Health Information (PHI); such data is governed by the Research Data Standard.

3. Classification Levels

All data must be classified into one of the following four levels. Classification is based on the type of data, its regulatory status, and the potential harm from unauthorized disclosure.

Level	Description	Examples
PUBLIC	Information approved for public release with no expectation of confidentiality.	Marketing materials, public website content, press releases, published research abstracts
INTERNAL	Information for internal business use only; not confidential but not intended for public release.	Internal memos, organizational charts, internal newsletters, non-sensitive meeting notes
CONFIDENTIAL	Information that could cause harm to individuals or the organization if disclosed without authorization.	Employee PII (SSNs, home addresses, payroll data), financial data, vendor contracts, internal audit reports
RESTRICTED	Information that could cause severe harm — including patient harm, major regulatory penalties, or loss of licensure — if disclosed, altered, or lost.	Patient medical records (PHI), authentication credentials, encryption keys, data covered by active litigation holds

Where data of different sensitivity levels is combined (e.g., a report containing both internal and PHI data), the entire dataset must be classified and protected at the **highest** applicable

level.

4. Policy Statements

4.1 Handling Requirements by Classification

Requirement	Public	Internal	Confidential	Restricted
Labeling Required	No	Yes (footer/header)	Yes (header, footer, and file name)	Yes (header, footer, file name, and system-level tag)
Encryption at Rest	No	Recommended	Yes	Yes (strong encryption, e.g., AES-256)
Encryption in Transit	No	Recommended	Yes (TLS 1.2+ or equivalent)	Yes (TLS 1.2+ or equivalent, mandatory — no exceptions)
Access Control	Open / no restriction	Authenticated employees (role-based, general access)	Role-based access, need-to-know, manager approval	Role-based access, strict need-to-know, formal approval + logging, MFA required

4.2 Labeling

Requirements:

- **PUBLIC:** No labeling required.
- **INTERNAL:** Documents must include "Internal Use Only" in the header or footer. File names should avoid implying external distribution.
- **CONFIDENTIAL:** Documents must include "CONFIDENTIAL" in the header and footer. File names must include the classification tag where practical (e.g., `Confidential_Q3_Financials.xlsx`).
- **RESTRICTED:** Documents must include "RESTRICTED — PHI" or the appropriate restricted marking in the header and footer. File names must include the classification

tag, and where technically supported, systems must apply a metadata classification tag that persists with the file (e.g., in the EHR and document management systems).

4.3 Storage

Requirements:

- **PUBLIC:** May be stored on any approved company system, including the public website and marketing platforms.
- **INTERNAL:** Must be stored on company-managed systems (internal file shares, approved collaboration tools). Storage on personal devices or personal cloud accounts is prohibited.
- **CONFIDENTIAL:** Must be stored only in approved, access-controlled systems (e.g., HR system, finance system, approved encrypted file shares). Storage on personal devices, removable media, or unapproved cloud services is prohibited.
- **RESTRICTED:** Must be stored only in systems specifically approved for PHI/Restricted data (e.g., the EHR system, approved encrypted clinical file storage), with encryption at rest mandatory. Storage on local workstation hard drives, personal devices, USB drives, or any unapproved system is strictly prohibited. Backups of Restricted data must be encrypted and access-controlled to the same standard as production data.

Prohibited locations for Confidential and Restricted data (all levels above Internal):

personal email accounts, personal cloud storage (e.g., personal Dropbox/Google Drive), unencrypted removable media, and any system not formally approved by IT Security.

4.4 Transmission

Requirements:

- **PUBLIC:** May be transmitted by any method, including standard email and public channels.
- **INTERNAL:** May be transmitted via company email and approved collaboration tools; should not be sent to personal email accounts.
- **CONFIDENTIAL:** Must be transmitted using encrypted email (e.g., company-approved secure email/encryption gateway) or an approved secure file transfer method. Must never be sent to personal email accounts or unencrypted external destinations.
- **RESTRICTED:** Must be transmitted only via encrypted, approved channels specifically authorized for PHI (e.g., the EHR's secure messaging function, encrypted secure email with delivery confirmation, approved secure file transfer). Faxing PHI is permitted only via a secure fax line per HIPAA-compliant procedures. Restricted data must never be sent via

standard unencrypted email, text message, or personal messaging apps, and must never be transmitted outside the organization without a signed Business Associate Agreement (BAA) or equivalent data processing agreement where required under HIPAA/GDPR.

4.5 Disposal

Requirements:

- **PUBLIC:** May be disposed of using standard waste disposal or deletion.
- **INTERNAL:** Paper must be placed in standard recycling or shredding bins; digital files may be deleted through standard system deletion.
- **CONFIDENTIAL:** Paper must be cross-cut shredded or placed in locked shredding bins for certified destruction. Digital media must be sanitized using a method consistent with NIST SP 800-88 (e.g., secure erase) before reuse or disposal.
- **RESTRICTED:** Paper must be cross-cut shredded or destroyed via certified secure destruction service with a certificate of destruction retained. Electronic media (hard drives, USB drives, backup tapes) must be sanitized or destroyed per NIST SP 800-88 guidelines (clear, purge, or destroy, based on media type and reuse plans), with destruction logged and retained per the records retention schedule. Devices that stored PHI must never be resold, donated, or discarded without verified sanitization.

4.6 Access Control

Requirements:

- **PUBLIC:** No access restriction; open to any audience.
- **INTERNAL:** Available to all authenticated employees; no special approval needed beyond standard network/system access.
- **CONFIDENTIAL:** Access limited to individuals with a defined business need (need-to-know), granted through role-based access control and approved by the relevant data owner or manager. Access reviewed at least annually.
- **RESTRICTED:** Access limited strictly to individuals with a documented clinical or business need, granted through role-based access control with formal approval from the data owner (e.g., Privacy Officer for PHI). All access to Restricted data must require MFA and must be logged. Access is reviewed at least quarterly, and any access to patient records must be consistent with HIPAA's "minimum necessary" standard. Access is revoked immediately upon role change or termination.

5. Roles and Responsibilities

Role	Responsibilities
Executive Management	Approve this policy and support organization-wide data classification practices
CISO / Privacy Officer	Own this policy, define and update classification criteria, oversee HIPAA/GDPR compliance for data handling, and approve access to Restricted data
Data Owners (Department/System Leads)	Classify data within their area of responsibility, approve access requests for Confidential data, and ensure handling requirements are followed
IT Security Team	Implement technical controls (encryption, access control, DLP, media sanitization), monitor for policy violations, and support classification tagging in systems
Health Information Management (HIM) / Medical Records Staff	Apply classification and handling requirements to patient records specifically, and support HIPAA-compliant release-of-information processes
All Employees, Contractors, and Vendors	Classify data they create or handle, follow handling requirements for each classification level, and report suspected mishandling or exposure
Research Compliance / IRB	Ensure research data classification and de-identification practices meet HIPAA and institutional requirements

6. Compliance

6.1 Monitoring

IT Security will use data loss prevention (DLP) tools, access logging, and periodic audits to monitor for unauthorized storage, transmission, or access of Confidential and Restricted data.

6.2 Reporting

Suspected data misclassification, mishandling, or exposure must be reported immediately to the Privacy Officer or IT Security at andrei@cyberdlh.lu or via the IT Service Desk.

6.3 Auditing

Data classification practices will be audited at least annually, including a review of access logs for Restricted data, sampling of stored/transmitted data for correct classification and handling, and verification of media sanitization records. Findings are reported to Executive Management and, where relevant, incorporated into the HIPAA Security Rule risk analysis.

7. Enforcement

7.1 Violations

Violations of this policy may result in:

- Verbal warning
- Written warning
- Suspension of system access privileges
- Mandatory retraining on data classification and handling
- Disciplinary action up to and including termination
- Legal or regulatory action where applicable, including HIPAA breach reporting obligations

7.2 Reporting Violations

Report suspected violations to the Privacy Officer, IT Security, or via the confidential compliance hotline.

8. Exceptions

8.1 Exception Process

Exceptions to this policy require:

1. A written request submitted to the Privacy Officer or CISO
2. A documented business or clinical justification
3. A risk assessment, including HIPAA/GDPR impact analysis
4. Compensating controls where applicable
5. Formal written approval and documentation retained by the Privacy Officer

8.2 Exception Duration

All exceptions must have a defined end date and be reviewed quarterly.

9. Definitions

Term	Definition
PHI (Protected Health Information)	Individually identifiable health information held or transmitted by a HIPAA-covered entity, in any form
PII (Personally Identifiable Information)	Information that can be used to identify a specific individual (e.g., name, SSN, address)
Personal Data (GDPR)	Any information relating to an identified or identifiable natural person, as defined in GDPR Article 4
Data Owner	The individual or department accountable for a specific dataset and responsible for its classification and access approval
Minimum Necessary Standard	The HIPAA principle requiring access to and disclosure of PHI be limited to the minimum necessary to accomplish the intended purpose
Media Sanitization	The process of removing data from storage media such that it cannot be reasonably recovered, per NIST SP 800-88
De-Identified Data	Data from which identifying information has been removed such that it can no longer reasonably be linked to a specific individual

10. Related Documents

- Quick Reference Guide: Data Classification (companion document)
- Acceptable Use Policy
- Password Policy
- Incident Response Policy
- Research Data Standard
- Records Retention Schedule
- NIST SP 800-60: Guide for Mapping Types of Information and Systems to Security Categories
- NIST SP 800-88: Guidelines for Media Sanitization
- HIPAA Security Rule (45 CFR Part 160 and Subparts A and C of Part 164)
- GDPR Article 4: Definitions (Personal Data)

11. Revision History

Version	Date	Author	Description
1.0	2026-08-19	CISO / Privacy Officer	Initial release, aligned with HIPAA Security Rule, GDPR, and NIST SP 800-60/800-88

12. Acknowledgment

By accessing HealthPlus Medical Group systems, all employees, contractors, and vendors acknowledge they have read, understood, and agree to comply with this Data Classification Policy.

For formal acknowledgment tracking, use the company's policy acknowledgment system.

End of Policy Document